Privacy & Security Research

Group Project 2 · Extension of the previous project · BSc Digital Forensics & Cyber Security

The idea

Last year we built SecDocVault, a Cross-platform Mobile app for keeping sensitive documents — IDs, medical records, that sort of thing — encrypted on the phone instead of sitting in the camera roll behind a lock screen. Under the hood, it used AES-256-GCM for the documents, Android Keystore for the master key, PBKDF2 for key derivation, and Firebase for authentication and storage, plus biometric/PIN login and auto-logout on inactivity.

This time we want to take it further and make it more research-driven. The project has two halves that feed into each other. The first half is a proper deep-dive into **privacy and data/document protection** — what it actually means to protect someone's data, what the law expects (GDPR and the rest), and how the cryptography and key management are meant to be done if you're doing it right. The second half involves us putting our own app on the table: a full **security test of SecDocVault** to see whether it really lives up to the privacy and security promises we made, and where the cracks are.

So the question we're chasing is basically: does an app like this genuinely protect your documents the way it claims, and how do you actually prove it? We answer that by pairing the theory (privacy law + cryptography literature) with hands-on testing (threat modeling, pentesting, crypto validation), and then comparing what was promised against what we actually find.

Contributors

Danyil Tymchuk · Artem Surszenko · Illia Stefanovskyi

What we want to cover

- **Privacy & data protection law** — GDPR, HIPAA, data minimisation, consent, privacy-by-design, and what "zero-knowledge" means legally vs technically.
- **Cryptography & key management** — authenticated encryption (AES-GCM), key

derivation (PBKDF2, Argon2), key hierarchies, hardware-backed storage (TEE / Android Keystore), and common crypto mistakes (IV reuse, weak randomness, padding).

- **Anonymity & digital fingerprinting** — anonymity vs pseudonymity vs unlinkability/unobservability, k-anonymity, and how a device or user gets fingerprinted on mobile (SSAID, build fingerprint, sensor-calibration drift, advertising ID, Play Integrity, JA3/JA4 TLS fingerprinting) — plus what our own app quietly leaks: EXIF/GPS in stored docs, analytics SDKs, traffic patterns.
- **Zero-knowledge architecture** — the theory behind it and how hard it actually is to pull off in a real cloud app.
- **Cloud & storage security** — Firebase configuration, data-at-rest and data-in-transit protection, access rules.
- **Data remanence & secure deletion** — when you delete a document, is it actually gone? Recovering it from device storage or Firebase, and validating secure-wipe behaviour. (Ties straight into GDPR's right to erasure, so it can sit under either the anonymity or data-protection subject.)
- **Threat modeling** — STRIDE applied to a mobile document vault, attack trees, attack surface.
- **Pentesting methodology** — OWASP MASVS/MSTG, PTES, NIST, and how we structure the testing.
- **The actual SecDocVault test** — static analysis, dynamic testing, crypto validation, auth & session testing, access-control checks, and config review.
- **Findings & fixes** — documented vulnerabilities, CVSS scoring, risk ranking, and remediation advice.
- **Post-quantum angle** — quick look at whether the crypto choices hold up against future threats.

How we're splitting the work

Instead of each person owning a whole chapter, we're splitting by theme — so one of us follows the privacy/legal thread the whole way through, one takes the cryptography thread, one drives anonymity & digital fingerprinting, and we are together doing the app-security and testing thread. Everyone's theme runs across the literature review, the analysis, and the testing chapter, so the work stays balanced and nobody's stuck with only writing or only testing. The intro, discussion, conclusions and references we do together.

Lead	Theme	Runs through	Main topics
Danyil	Anonymity & digital fingerprinting	Lit Review A, fingerprinting in architecture, de-anonymisation & fingerprinting testing, data remanence	anonymity vs pseudonymity vs unlinkability (Pfitzmann–Hansen), k-anonymity, mobile fingerprinting vectors (SSAID, build fingerprint, sensor drift, ad ID, Play Integrity, JA3/JA4), device-binding bypass, EXIF/metadata leakage, secure deletion
Artem	Privacy & data protection	Lit Review B, Privacy Analysis, data-protection testing, compliance comparison	GDPR, HIPAA, privacy-by-design, data minimisation, zero-knowledge (legal view)
Illia	Cryptography & implementation	Lit Review C, crypto architecture, crypto validation testing, future-proofing	AES-GCM, PBKDF2/Argon2, key management, Keystore/TEE, IV handling, post-quantum
Together	App security & testing	Methodology, threat model, auth/access-control/Firebase testing, findings	STRIDE, OWASP/PTES, pentest, auth & sessions, access control, CVSS, remediation
Together	Shared	Intro, Discussion, Conclusions, References & Appendices, presentation	synthesis, peer review, GitHub, citations

Full breakdown with chapter links and estimated pages lives in the companion sheet.